



Identity and Access Management Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	4
2. Functional Scope and Target Groups	5
2.1. Functional scope of applicability	5
2.2. Target groups	5
2.3. Transition period	6
3. Definitions	7
3.1. Requirements	7
3.2. Explanation of requirements and key definitions	8
3.3. Account types	9
4. Requirements	11
4.1. Control requirement	11
5. Roles and Responsibilities	33
5.1. Creator	33
5.2. Guideline Owner	33
6. Appendix	34
6.1. Contact Information	34
6.2. Document History	34
6.3. Related Written Rules	34
6.4. Abbreviations	35

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The Identity and Access Management Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in this policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Govern	8. Segregate conflicting duties and conflicting areas of responsibility.	4.1
Protect	1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT Written Rules framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC¹, data management and other controls addressing poor administration and human error risks.	4.3
Protect	7. Restrict and manage the allocation and use of privileged access rights.	4.3

Table 1: Minimum Requirements

¹ IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; Chief Compliance Officer Area; or any other area that owns Identity and Access Management topic

Table 2: Scope

2.2. Target groups

Within the scope of the current Identity and Access Management Guideline below is addressed the list of applicable target groups and operation areas²:

Target group	Key message
ICT Risk Oversight	To oversee, implement and manage IAM solutions and security policies (incl. access controls).
ICT Operational Management	To implement and maintain technical measures that support the overall implementation and maintenance of ICT Systems to ensure efficiency.
Business Management	To manage employee access rights.

Table 3: Target groups

² For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

3.3. Account types

A distinction is made between the following account types:

Account type	Shared	Special requirements
Personal account	No	Must not be used for privileged access.
Personal privileged account	No	Only to be used for privileged access.
Shared account	Yes	Responsible Account Owners (Account Owner Work Group) must be assigned and documented to the shared account. If shared accounts are used for privileged access, they must be managed and secured like privileged accounts.
Technical account (incl. service accounts)	No	Interactive log-on is prohibited. For the following guideline, technical accounts are defined as a subset of non-personal accounts. Independent of the classification of privileged accounts, technical accounts are always to be classified as privileged. The Account Owner Work Group must be assigned and documented to the technical account.
Emergency account	Yes	Emergency accounts are used to restore service after large disruptions, where availability of infrastructure and security services cannot be guaranteed. Responsible Account Owners (Account Owner Work Group) must be assigned and documented to the emergency account. Emergency accounts must be managed and secured by the Account Owner ³ . Emergency Accounts must be documented in the authorization concept and reported to PAI ⁴ .
Break Glass account	Yes	Break Glass accounts are invoked to restore apps and infrastructure under the assumption, that security services and other apps are available. Responsible Account Owners (Account Owner Work Group) must be assigned and documented to the Break Glass account. Break Glass accounts must be managed and secured as privileged access. Break glass accounts must be documented in authorization concept and reported to PAI.

Access must be classified in one of the following categories: Privileged access, non-privileged access, business-critical access, and business non-critical access, depending on the IT Asset criticality and entitlements of accounts used for asset access.

Privileged access:

Privileged access as defined below is in scope of this Guideline.

Privileged access fulfills the following criteria:

³ Please refer to the definition for 'Account Owner' in the ICT Risk Glossary.

⁴ PAI refers to the privileged access inventory – the inventory of all privileged accounts for a given LE.

- Can change IT Asset configuration to perform unintended activities OR
- Can create IT Asset internal accounts AND assign access rights to them OR
- Can change roles/entitlements OR
- Can operate outside of IT Asset operational logic and thus can circumvent IT Asset-related security controls (i.e., manipulate log files, redirect IT Asset traffic, circumvent security controls).

Non-privileged access:

Access to business applications and all non-privileged access to all IT Asset types are subject to the Identity and Access Management controls since they are not considered as privileged. This also includes Tier-2 access since it does not fulfil the privileged access criteria. Non-privileged access must be controlled and thus IT Asset-related security controls are applied consistently.

Business-critical access:

Business-Critical Access (BCA) is considered non-privileged access to IT Applications⁵ that supports critical or important functions.⁶

For the avoidance of doubt: This Guideline shall not comprise requirements for the processing of individual's personal data as such legal requirements are already reflected in the Data Protection Policy or similar legal entity related/associated documentation.

⁵ Please refer to the asset types of Asset Category Level 3: 'IT Applications' in ICT Asset Management Guideline for more detail.

⁶ Please refer to the CIF Identification Procedure of the Written Rules Database on the intranet for further details.

4. Requirements

4.1. Control requirement

ID: 1 (version 2.0)	IAM Rules & Procedures
1 DOR.ICT.IAM.PRC.001	For Identity and Access Management, procedures and controls must be defined, implemented, and performed.
1.1 DOR.ICT.IAM.PRC.002	A formal access management process, which includes the review and authorization of access requests by responsible authorities prior to provisioning, must be established, documented, and applied for all accounts and access rights. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.20 1)
1.2 DOR.ICT.IAM.PRC.003	Access requests and access provisioning for primary and secondary access must be documented accordingly. A central record must be available, preferably via a designated IAM tool, and allow the tracking of individual requests by MyUserID. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.20 1)
1.3 DOR.ICT.IAM.PRC.004	Access requests must be reviewed and authorized by responsible authorities or persons. An additional approval by the Role Owner is required for business-critical access. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.20 1)
1.4 DOR.ICT.IAM.PRC.005	Automated access provisioning must be established. If not possible, complementary controls must be designed, implemented, and described in the Authorization Concept. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance Key References: DORA RTS RMF A.20 1)
1.5 DOR.ICT.IAM.PRC.006	An identity lifecycle process is established and must manage the creation, change, review and update, temporary deactivation, and termination of all accounts. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance Key References: DORA RTS RMF A.20 2b)

ID: 1 (version 2.0)	IAM Rules & Procedures
1.6 DOR.ICT.IAM.PRC.007	Entitlements in affected target ICT Systems and validation of entitlement creation by reconciliation between target ICT System and requested access must be enforced daily (including automated synchronization and clean-up of identified deviations). If not possible, complementary controls must be designed, implemented, and described in the Authorization Concept. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
1.7 DOR.ICT.IAM.PRC.008	Applications should automatically be reconciled. If automatic reconciliation is not possible, complementary controls must be designed and implemented. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0

ID: 2 (version 2.0)	IAM Definition of Access Rights
2 DOR.ICT.IAM.ACC.001	Access Rights for Identity Access Management must be defined and documented.
2.1 DOR.ICT.IAM.ACC.002	Access rights including remote and emergency access must be assigned and provisioned for IT Assets based on need-to-know, need-to-use and least privilege principles. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21 1a)
2.2 DOR.ICT.IAM.ACC.003	Access rights must be designed in alignment with the information classification of the information asset. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
2.3 DOR.ICT.IAM.ACC.004	It must be ensured that roles and responsibilities are assigned to grant, review, and revoke access rights. Retention periods for logs must be defined in accordance with business and information security objectives, reason for event recording and results of the ICT risk assessment. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21 1e.i)

2.4 DOR.ICT.IAM.ACC.005	Role composition must be documented at the level of entitlements in a central tool. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
2.5 DOR.ICT.IAM.ACC.006	Changes to the role composition must be processed (i.e. documented, approved, and tested) based on the change management process required in the Software and Change Management Guideline. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18

ID: 3 (version 2.0)	Segregation of Duties
3 DOR.ICT.IAM.SOD.001	Segregation of Duties (SoD) must be defined, applied, and controlled to prevent any unauthorized access to sensitive data, circumventing access controls or conflicting business interests.
3.1 DOR.ICT.IAM.SOD.002	The Business Owner is responsible to assign all roles and entitlements to SoD areas⁷ for which Segregation of Duty is required and must be implemented at technical level. Roles assigned to SoD areas must be documented (e.g. in the Authorization Concept of the IT Asset). Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)
3.2 DOR.ICT.IAM.SOD.003	SoD lifecycle change process must be documented.⁸ Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)
3.3 DOR.ICT.IAM.SOD.004	Entitlements compositions must not contain any SoD conflict in itself. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)
3.4 DOR.ICT.IAM.SOD.005	Confirmed toxic SoD combinations must not be (re-) approved (ID 15 for further details).

⁷ Please refer to the SOD Matrix provided by Group Compliance on the intranet for further details. The functional SoD areas, where required, are defined by the Business Owner for specific applications.

⁸ Please refer to <https://deutscheboerse.sharepoint.com/sites/IN-Group-Compliance/SitePages/IT%20Compliance%20SoD.aspx> provided by Group Compliance on the intranet for further details.

	Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)
3.5 DOR.ICT.IAM.SOD.006	Entitlements compositions must be assessed with respect to SoD requirements to enable SoD checks based on defined rules. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)
3.6 DOR.ICT.IAM.SOD.007	SoD must be reflected in the role composition. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)
3.7 DOR.ICT.IAM.SOD.008	The IT access rights allocated to staff must not conflict with any SoD defined rules. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)
3.8 DOR.ICT.IAM.SOD.009	While requesting and before assigning access to an account, SoD check and handling must be performed. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)
3.9 DOR.ICT.IAM.SOD.010	SoD conflicts must be classified and handled according to the defined and implemented SoD processes. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware Key References: DORA RTS RMF A.2g, A.21.1b)

ID: 4 (version 2.0)	IAM Authorization concept
4 DOR.ICT.IAM.DOC.001	For each IT Asset an authorization concept must be developed, implemented, and kept up to date to prevent any unauthorized access or breach of access controls.
4.1 DOR.ICT.IAM.DOC.002	An Authorization Concept must cover at least the following scope items: Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21d)

4.1.1 DOR.ICT.IAM.DOC.003	The Authorization Concept must be established based on the security requirements, business needs and the corresponding processes. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21d)
4.1.2 DOR.ICT.IAM.DOC.004	The Authorization Concept must define the complete design and content of roles and entitlements. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21d)
4.1.3 DOR.ICT.IAM.DOC.005	The Authorization Concept must define the design and management of user authorization and access (de-) provisioning. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21d)
4.1.4 DOR.ICT.IAM.DOC.006	The Authorization Concept must describe how emergency access is managed and controlled. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21d)
4.1.5 DOR.ICT.IAM.DOC.007	The Authorization Concept for the network infrastructure must define and describe the network access controls. Asset-Types: Business Process Key References: DORA RTS RMF A.21d)
4.2 DOR.ICT.IAM.DOC.008	Authorization Concepts must be reviewed at least every 12 months and updated in case of changes. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21d)
4.3 DOR.ICT.IAM.DOC.009	Authorization Concepts must be approved prior to activating access rights. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21d)
4.4 DOR.ICT.IAM.DOC.010	The Information Owner of the adopting LE using the application must review the Authorization Concept.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0
--	--

ID: 5 (version 2.0)	Access Control
5 DOR.ICT.IAM.ACO.001	Access controls must be defined, implemented, monitored and controlled to prevent any unauthorized access, avoid breach of access controls and restrict access to support the protection requirements considering each level of classification.
5.1 DOR.ICT.IAM.ACO.002	Unauthorized access must be defined, identified, prevented and denied by controls and measures for IT Assets and Non-IT Assets⁹. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Building, Room, Datacenter Key References: DORA 2022/2554 A.9.4 c)
5.3 DOR.ICT.IAM.ACO.004	Entitlements for access to different Segregation Areas must only be assigned to users reflecting SoDs to access different Segregation Areas. Where separation of environment or duties is difficult (activities in the Green and Red Segregation Areas development and production activities performed by same teams), other controls such as monitoring of activities, audit trails and management supervision must be implemented. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.31
5.4 DOR.ICT.IAM.ACO.005	User accounts should be clearly distinguishable in context of the user interface. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage Key References: ISO 27001:2022 Cor 202203 A.5.15
5.6 DOR.ICT.IAM.ACO.007	At least all accesses to Red and Yellow Segregation Area must be logged and all ICT Systems and users must only have access to networks and network services that they have been specifically authorized to use based on the need-to-know principle. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware

⁹ Non-IT Assets are addressed in the Human-related ICT Management Guideline, Third Party ICT Risk Management Guideline and Data Centre and Physical Protection Guideline.

	Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage Key References: DORA RTS RMF A.12c.i)
5.7 DOR.ICT.IAM.ACO.008	Controls must be designed and implemented to limit physical or logical access to Information Assets, IT Assets and Non-IT Assets fulfilling this Guideline which refers to access rights and access rights administration. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Building, Room, Datacenter Key References: DORA 2022/2554 A.9.4 c)

ID: 6 (version 2.0)	IAM Identification
6 DOR.ICT.IAM.UID.001	Controls and measures must be designed, implemented and managed to ensure that access to information and IT Assets are conducted using a unique identity. The established IAM lifecycle process must manage and control these unique identities.
6.1 DOR.ICT.IAM.UID.002	All internal and external individuals, who have access to Information Assets and IT Assets, must have a unique, global user ID ("MyUserID") linked to a unique account. These accounts (other than shared accounts) must be linked to a MyUserID to remain traceable. Asset-Types: Business Process Key References: DORA RTS RMF A.20 2a)
6.2 DOR.ICT.IAM.UID.003	Information on the creation, modification or deletion of unique identifiers assigned to unique user accounts must be logged, monitored, maintained and kept for at least 18 month – even following a reorganization or end of a contractual relationship with the user. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.20 2a)

ID: 7 (version 2.0)	Contractual obligations regarding information security
7 DOR.ICT.IAM.CON.001	Contractual obligations must consider the organisations demand on information security to ensure adherence and to prevent information leakage.
7.1 DOR.ICT.IAM.CON.002	Personal secret authentication information such as passwords, PINs, keys, and tokens must never be shared or be made accessible to any other individual. The correct handling of cryptographic products and key material must be ensured and documented, and employees must be properly trained.

	Asset-Types: Information, Business Process, Certificate Key References: ISO 27001:2022 Cor 202203 A.5.17
7.2 DOR.ICT.IAM.CON.003	Only approved authentication mechanisms must be utilized by the contracting party. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
7.3 DOR.ICT.IAM.CON.004	When users are provided with new or updated secret authentication information, they must get temporary credentials, which must be changed upon first use. The secret authentication information must be valid for no longer than 24 hours. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
7.4 DOR.ICT.IAM.CON.005	Legal entity's authentication information must not be used for non-business purposes. This includes but is not limited to not using the same password for the legal entity used and privately used user accounts. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.17
7.5 DOR.ICT.IAM.CON.006	Secret authentication information must be changed when suspected of compromise. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.17

ID: 8 (version 2.0)	Password management
8 DOR.ICT.IAM.PWM.001	Passwords and PINs must be defined, kept safe and managed securely.
8.1 DOR.ICT.IAM.PWM.002	Login-credentials must consider the following: Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0
8.1.1 DOR.ICT.IAM.PWM.003	Secret authentication information such as passwords, PINs, keys and tokens must be classified as strictly confidential and protected by cryptographic measures. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host

	Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.1.2 DOR.ICT.IAM.PWM.004	Passwords must not be displayed by default as clear characters on the screen when being entered but must be hidden. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.1.3 DOR.ICT.IAM.PWM.005	Where possible, legal entity owned ICT Systems should leverage central identity provider services, which manage the user passwords. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.1.4 DOR.ICT.IAM.PWM.006	User passwords (including technical accounts) must not be stored in ICT Systems in plaintext format, should be suitably protected and stored separately from ICT System data. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.1.5 DOR.ICT.IAM.PWM.007	User passwords must be protected by encryption during their transmission. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.1.6 DOR.ICT.IAM.PWM.008	Password transmission must be justified and authorized. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.1.7 DOR.ICT.IAM.PWM.009	Only authorized individuals and components must be allowed to trigger the change of passwords. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17

8.2 DOR.ICT.IAM.PWM.010	A password management policy must be enforced with at least the following criteria: Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.2.1 DOR.ICT.IAM.PWM.011	Passwords for primary access must be at least 14 characters long with a lifelong validity. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.2.2 DOR.ICT.IAM.PWM.012	Passwords for non-privileged secondary access must be at least 14 characters long with a lifelong validity. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.2.3 DOR.ICT.IAM.PWM.013	Passwords for privileged access must be changed at least every 90 days. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
8.2.4 DOR.ICT.IAM.PWM.014	If 14 characters are technically not feasible, passwords must be at least 8 characters long and must be changed at least every 90 days. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.2.5 DOR.ICT.IAM.PWM.015	New passwords must be different from at least the last 6 passwords. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.2.6 DOR.ICT.IAM.PWM.016	Initial account passwords must be set up by Account Owners, latest during the first login to the ICT System. Alternatively, users might be given a temporary password by the ICT System administrator that must be changed during first login. This temporary password must be valid for no longer than 24 hours. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device,

	Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.2.7 DOR.ICT.IAM.PWM.017	Password reset or recovery processes must follow the same rules as the initial password setup. Additionally, the identity of the requestor must be verified by the Asset Owner. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.2.8 DOR.ICT.IAM.PWM.018	All default ICT System accounts must be removed, disabled, or have their default passwords changed. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.2.9 DOR.ICT.IAM.PWM.019	A password must at least contain characters of each of the following categories: upper case characters, lower case characters, numbers, special characters. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.3 DOR.ICT.IAM.PWM.020	Every password change / reset must be logged and forwarded to SIEM. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.4 DOR.ICT.IAM.PWM.021	PINs must be at least 4 digits long and have a lifelong validity. Following a risk-based approach, the minimum number of digits must be increased. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.17
8.5 DOR.ICT.IAM.PWM.022	Policies and protocols for strong authentication mechanisms must be designed, implemented and controlled based on results of the data classification and the outcome of the ICT risk assessment processes (e.g., cryptographic measures must be commensurate to the classification of the data). Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.9.4 d)

8.6 DOR.ICT.IAM.PWM.023	Any credentialing concept that utilizes other means than passwords, such as passphrases, must provide bit entropy at least on the same level as the current password policy. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.9.4 d)
--	--

ID: 9 (version 2.0)	Secure authentication mechanisms
9 DOR.ICT.IAM.SAM.001	Secure authentication mechanisms must be defined, developed, and applied.
9.1 DOR.ICT.IAM.SAM.002	All legal entity owned ICT Systems must allow access to their resources only after users have been successfully authenticated and authorized. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.2 DOR.ICT.IAM.SAM.003	Confidential data must be accessible only if the user is authenticated with a strong two- or multi-factor authentication. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.3 DOR.ICT.IAM.SAM.004	Where possible, ICT Systems should leverage Single-Sign-On (SSO) features provided centrally. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.4 DOR.ICT.IAM.SAM.005	If user credentials input is required, the log-on process must follow the following criteria: Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.4.1 DOR.ICT.IAM.SAM.006	Log-on information must be validated only upon completion of all input data. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile

	Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.4.2 DOR.ICT.IAM.SAM.007	Authentication information, such as credentials, is only evaluated on the target ICT System, not on the client device. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.4.3 DOR.ICT.IAM.SAM.008	Brute-force protection must be implemented. The account must be locked after a maximum of 10 unsuccessful log-on attempts. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.4.4 DOR.ICT.IAM.SAM.009	When log-on fails, the error message must not provide any information to the user on the root cause of log-on failure. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.5 DOR.ICT.IAM.SAM.010	Depending on the criticality of confidentiality and authenticity protection goal and exposure of the IT Application, the IT Application must use dedicated robust authentication schemes. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance Key References: ISO 27001:2022 Cor 202203 A.5.17
9.6 DOR.ICT.IAM.SAM.011	For multi-factor authentication, only standard legal entity approved solutions must be used as the second and additional factors. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203
9.7 DOR.ICT.IAM.SAM.012	Two- or multi-factor authentication must be enforced, independent from legal entity's endpoints. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Storage Media, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.8 DOR.ICT.IAM.SAM.013	Locked accounts can only be released after secure user identity validation. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile

	Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203
9.9 DOR.ICT.IAM.SAM.014	Unlock of locked accounts must be justified, authorized, and documented. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.10 DOR.ICT.IAM.SAM.015	Any successful / unsuccessful log-on attempts must be logged. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.5
9.11 DOR.ICT.IAM.SAM.016	Authentication methods must be applied according to the established classification for Identity and Access Management and the overall risk profile of IT Assets. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.21 1f.i)
9.12 DOR.ICT.IAM.SAM.017	Strong authentication methods must be established for remote access, for privileged access, for access to IT Assets supporting critical or important functions or for IT Assets that are publicly accessible. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.21 1f.ii)
9.13 DOR.ICT.IAM.SAM.018	A risk-based authentication concept for web-based IT Applications and those capable of handling federation protocol-based tokens must be implemented. The authentication strength must be in line with the Segregation Area and the application protection needs. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance Key References: ISO 27001:2022 Cor 202203 A.5.17

ID: 10 (version 2.0)	Non-privileged Access Administration
10 DOR.ICT.IAM.PRI.001	Primary and secondary accesses must be defined, assigned, documented, managed, and controlled.
10.1 DOR.ICT.IAM.PRI.002	The primary and secondary access to legal entities' ICT Systems must be activated or de-activated based on the information provided by HR and/or Third-Party Management.

	Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.16
10.2 DOR.ICT.IAM.PRI.003	Removal or adjustment of access must be processed timely in the target ICT System. If this cannot be done automatically, complementary controls must be in place to ensure near-time processing: 'Near-time' should be determined as 1 working day for publicly-accessible-applications that have at least one protection goal classified critical, and 3 working days for all other applications. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
10.3 DOR.ICT.IAM.PRI.004	Inactive primary access accounts must be identified and deactivated after an inactivity period of 30 days. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
10.4 DOR.ICT.IAM.PRI.005	Based on HR's information about individuals leaving the company, primary access must be revoked on the first day after the leaver date, secondary access, and all access rights within three working days, all accounts must be removed as soon as possible – latest within 42 days. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203
10.5 DOR.ICT.IAM.PRI.006	In case a user moves within the organization, all existing access related to the user must be recertified by the new line manager within two weeks. This includes only secondary access that was explicitly requested and not primary access. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18

ID: 11 (version 2.0)	Shared and non-personal accounts
11 DOR.ICT.IAM.SHA.001	Shared and non-personal accounts must be defined, assigned, documented, managed, and controlled to prevent any unauthorized access or breach of access controls.
11.1 DOR.ICT.IAM.SHA.002	Non-personal accounts and shared user accounts must be limited, inventoried and the traceability to responsible persons must be ensured.

	Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21 1c)
11.2 DOR.ICT.IAM.SHA.003	Each shared account is assigned to an Account Owner, who is responsible for maintaining an inventory of all individuals that have access to the shared accounts. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21 1c)
11.3 DOR.ICT.IAM.SHA.004	Login-credentials of shared / non-personal accounts as well as all secret authentications must be securely created, stored in a vault and handled. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
11.4 DOR.ICT.IAM.SHA.005	Login-credentials for shared user IDs remaining active should be changed upon termination or change of employment, contract, or agreement. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
11.5 DOR.ICT.IAM.SHA.006	In case identity / personal account is decommissioned, ownership of corresponding shared accounts must be reviewed and updated, if necessary. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
11.6 DOR.ICT.IAM.SHA.007	Interactive shared accounts must be traceable for all actions to an individual person and limited to actions by one individual at any given time. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2

ID: 12 (version 2.0)	Privileged account administration
12 DOR.ICT.IAM.PAM.001	Privileged accounts (PAM) must be defined, assigned, documented, managed, monitored and controlled to avoid unauthorized usage and harm to IT Assets.

12.1 DOR.ICT.IAM.PAM.002	Privileged, emergency and administration access rights must be assigned on a need-to-use or ad-hoc basis for all ICT Systems. Where feasible, for administration, dedicated accounts must be used and automated privileged access management procedures must be implemented. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21 1e.ii)
12.2 DOR.ICT.IAM.PAM.003	The interactive use of privileged built-in accounts must be prevented and if applicable, the entitlements of these accounts must be transferred to dedicated user IDs. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
12.3 DOR.ICT.IAM.PAM.004	Privileged access must always be marked as such in Authorization Concept. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
12.4 DOR.ICT.IAM.PAM.005	Privileged access must be classified and controlled according to their level of criticality on a risk-based approach. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
12.5 DOR.ICT.IAM.PAM.006	Privileged built-in accounts must be classified and documented in the Authorization Concept. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
12.6 DOR.ICT.IAM.PAM.007	All privileged accounts must be inventoried in a privileged account inventory. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
12.7 DOR.ICT.IAM.PAM.008	Onboarded and managed in PAM: Privileged accounts must be secured in the vault of a Privileged Access Management (PAM) solution. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2

12.8 DOR.ICT.IAM.PAM.009	Completeness, currentness, and accuracy of the privileged account inventory must be ensured. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
-----------------------------	--

ID: 13 (version 2.0)	Mechanisms to secure privileged accounts
13 DOR.ICT.IAM.PVL.001	Measures and criteria to manage and handle privileged accounts must be defined, implemented, monitored and controlled to avoid unauthorized usage and harm to IT Assets.
13.1 DOR.ICT.IAM.PVL.002	Idle Session Timeout: The use of privileged access must be time-limited based on their level of criticality. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
13.2 DOR.ICT.IAM.PVL.003	Separate privileged from non-privileged account: Dedicated user IDs must be created and used for privileged access. Dedicated user IDs must be marked and identifiable for privileged access. Privileged access must not be assigned to user IDs with regular business / IT roles and must be provided based on the function using the least privilege principle. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21 1e.ii)
13.3 DOR.ICT.IAM.PVL.004	Release of locked privileged accounts must be detected and justified. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2

ID: 14 (version 2.0)	Privileged account monitoring
14 DOR.ICT.IAM.PAL.001	Privileged accounts must be monitored and logged. The details must be made available to the Security Information and Event Management (SIEM) for analysis and detection of unauthorized privileged accesses.
14.1 DOR.ICT.IAM.PAL.002	Logging and Monitoring: Logs must be made available for Security Information and Event Management (SIEM) in a structured way to allow the detection of unauthorized privileged accesses.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
14.2 DOR.ICT.IAM.PAL.003	Access to privileged accounts must be technically enforced to require a valid approved change request, ICT incident ticket, or a reference to a catalog of recurring routine activities. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
14.3 DOR.ICT.IAM.PAL.004	Video Session Recording / Text / Key stroke Logging: Any interactive use of privileged accounts by individuals must be recorded through the PAM solution and regularly reviewed on a risk basis. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ICT Risk Framework 1.0
14.4 DOR.ICT.IAM.PAL.005	Credentials Obfuscation (Disable Password View / Copy): The passwords for privileged accounts must remain hidden and must not be subject to copying. De-obfuscation for Emergency Accounts and Break Glass Accounts is allowed, provided that: Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
14.4.1 DOR.ICT.IAM.PAL.006	all other Privileged Access Management (PAM) control requirements in ID: 11, 12 and 13 are implemented (including traceability to individuals); Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
14.4.2 DOR.ICT.IAM.PAL.007	passwords must be automatically rotated after being retrieved from the secure storage and utilized; Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
14.4.3 DOR.ICT.IAM.PAL.008	any use of emergency access must be documented, and a Security Information and Event Management (SIEM) alert must be sent in the event of account usage. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile

	Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
--	--

ID: 15 (version 2.0)	Recertification
15 DOR.ICT.IAM.REC.001	The recertification of access rights and role compositions must be defined, integrated in the access procedure, monitored and controlled.
15.1 DOR.ICT.IAM.REC.002	The following types of recertification must be performed and documented: Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
15.1.1 DOR.ICT.IAM.REC.003	User access recertification must take place every 6 months for business-critical access and for privileged access of all levels by the responsible Line Manager and respective Role Owners. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
15.1.2 DOR.ICT.IAM.REC.004	User access recertification must take place every 12 months for all other accesses by the responsible Line Manager. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, IDP, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.21 1e.iv)
15.1.3 DOR.ICT.IAM.REC.005	The following types of recertification must be performed and documented: Role composition recertification by the Role Owner and Asset Owner must take place every 12 months and must include birth right roles. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
15.2 DOR.ICT.IAM.REC.006	All unauthorized access, which has been identified during the recertification process, must be revoked after the recertifier's sign-off. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, IDP, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
15.3 DOR.ICT.IAM.REC.007	Dedicated access to legal entity data must be reviewed at least once every 12 months by an employee of the respective legal entity. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud

	Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
--	--

ID: 16 (version 2.0)	Requirements for Tier-0 accounts
16 DOR.ICT.IAM.T0A.001	Tier-0 access must be managed, secured and kept safe.
16.1 DOR.ICT.IAM.T0A.002	Tier-0 access must additionally comply with the following control requirements: Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
16.1.1 DOR.ICT.IAM.T0A.003	Threat Analytics SIEM / PAM: Session monitoring solution must allow for data analysis / logging of actions made by privileged access. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
16.1.2 DOR.ICT.IAM.T0A.004	Maximum Session Time / Time-limited Access: Use of privileged access must be time-limited to the necessary minimum. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2
16.1.3 DOR.ICT.IAM.T0A.005	In emergency situations ¹⁰ , the approval for privileged access must occur through the responsible Manager on Duty. The Ticket Owner must ensure that the ICT incident documentation including approval is provided within 24 hours. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Operating System, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.2

ID: 17 (version 2.0)	IAM for Cloud
17 DOR.ICT.IAM.CLD.001	A procedure for Cloud Identity Access Management must be defined, implemented, monitored and controlled to protect against unauthorized usage or privilege escalation of Cloud-related accounts.

¹⁰ For further details, refer also to the ICT Incident & Operational Event Management Guideline, in Chapter 3 Definitions "Major ICT-related Incident" and if escalation occurs, also ID 21 of the ICT Operations Guideline.

17.1 DOR.ICT.IAM.CLD.002	Federated identities should be used, controlled, and traceability of access must be ensured. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Supplier Key References: ISO 27001:2022 Cor 202203 A.5.18
17.2 DOR.ICT.IAM.CLD.003	Federated identities must be technically linked to a valid MyUserID or Account Owner Workgroup. Asset-Types: Business Process, SaaS, Cloud Appliance, Cloud PaaS Key References: ISO 27001:2022 Cor 202203 A.5.18
17.3 DOR.ICT.IAM.CLD.004	Access event logs to IT Assets must be available and monitored. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.18
17.4 DOR.ICT.IAM.CLD.005	CSP must only be able to access legal entity data and ICT Systems in the cloud after prior and explicit approval for each individual case. Asset-Types: Information, Business Process, Certificate, Cloud Appliance, Cloud PaaS, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.3
17.5 DOR.ICT.IAM.CLD.006	Access requests by CSPs personnel to legal entity's data must go through an access request process that requires explicit approval by the respective information owner. Asset-Types: Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS Key References: ISO 27001:2022 Cor 202203 A.8.3
17.6 DOR.ICT.IAM.CLD.007	The CSP must only be able to use "just in time" (temporary) credentials when technically feasible rather than persistent credentials based on the service models. Asset-Types: Business Process, SaaS, Cloud Appliance, Cloud PaaS Key References: ISO 27001:2022 Cor 202203 A.8.3
17.7 DOR.ICT.IAM.CLD.008	Access to cloud environments must be restricted and, where possible, only via the programmatic call of APIs ("infrastructure-as-code"). Asset-Types: Business Process, SaaS, Cloud Appliance, Cloud PaaS Key References: ISO 27001:2022 Cor 202203 A5.18
17.8 DOR.ICT.IAM.CLD.009	Cloud assets must use accounts which are centrally managed by the IAM process. Asset-Types: Business Process, SaaS, Cloud Appliance, Cloud PaaS Key References: BaFin Aufsichtsmittelung zu Auslagerungen an Cloud Anbieter IV.1.3

5. Roles and Responsibilities

5.1. Creator

The creator of the Identity and Access Management Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of the Identity and Access Management Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the Identity and Access Management Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the Identity and Access Management Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner = Head of ICT Risk Governance & Advisory

Please contact ICT Risk Governance & Advisory in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual guideline review with material changes

Coordination before publication

Version	Date	Task	Name
2.0	09.04.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	08.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	08.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	n/a

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****

